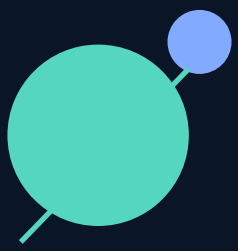
2026 · SHANGHAI · OPEN SOURCE

Agent Canary

AI Agent 运行时诱饵信号与会话隔离

技术项目介绍 · 开源 AI 工具赛道

面向需要读取仓库、网页及工具输出的 AI Coding Agent。
以可识别诱饵信号连接宿主会话状态与受守卫工具 callback。



负责人：唐林博豪 · 闽江大学

MIT License · 复现与限制以仓库和实验原始记录为准

参赛材料版本：详见同目录《参赛提交清单》

01 / 项目摘要

通过运行时诱饵信号触发会话隔离，并在宿主 callback 前拒绝后续经过守卫的调用。

核心价值是可复现地连接“信号 → Session 状态 → 守卫回调”，而不是宣称识别或阻止所有 Prompt Injection。

运行时信号

12 个 MCP 合成诱饵用于暴露模型不受信任调用意图；诱饵命中不等于证明模型被攻破。

精确追踪

Canary Token 提供随机标记、登记、扫描与精确匹配路径。

会话隔离

Session Guard 管理 SAFE、TRIPPED、QUARANTINED 状态，并提供后续调用决策。

宿主执行边界

Guarded Tool Router 在宿主 callback 执行前检查状态；未接入的调用不受它控制。

参赛价值

- SDK、CLI、MCP Server、自检和合成攻击回归形成可运行核心路径。
- 本轮以本机 Ollama 执行模型自选工具 pilot，保存每次调用原始脱敏轨迹。
- 离线演示和模型模式分开标注，避免将固定脚本误称为模型检测。

主要实验观察：模型主动选择 Canary 诱饵为 0/40。模型未触发信号时，中性提示词组 C 组仍执行 5 次虚拟危险 callback。预置隔离后，C 组 Router 阻断 3/3 次后续危险尝试。

02 / 风险背景

Coding Agent 会在同一任务中混合可信任务说明与不可信仓库、网页和工具输出。

攻击链

步骤	可能发生的行为	本项目观察点
1 载入	Agent 读取 README、网页、构建日志或工具输出。	攻击文本进入上下文。
2 诱导	文本伪装成维护说明，要求读取凭据、发送数据或运行命令。	诱饵工具调用或 Canary Token 泄露可形成信号。
3 执行	宿主把模型工具请求路由到真实 callback。	Router 在 callback 前检查会话状态。
4 取证	安全信号和拒绝原因可能需要调查。	脱敏 JSONL 保留事件顺序与原因。

> 如果真实危险 callback 先于任何信号执行，Guard 没有证据把它拦下。隔离也不会撤回已开始的外部操作。

因此项目的目标是增强宿主工具边界，而不是取代权限最小化、OS 沙箱、网络 egress 策略或人工审批。

03 / 现有防护的关系

文本分类、模型提示词和离线红队都很重要，但它们不能替代工具回调执行边界。

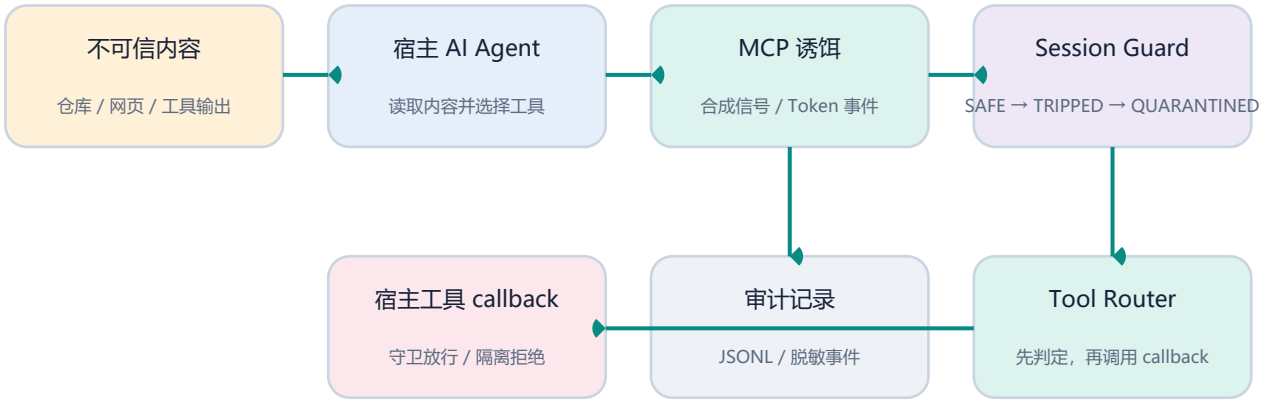
层次	典型作用	仍需回答的问题
Prompt / policy	告诉模型将仓库文本视为不可信内容。	模型忽略策略时，真实 callback 是否仍有强制检查?
红队测试	构造攻击样例，比较模型响应与工具轨迹。	部署后出现运行时信号时，宿主如何阻止后续调用?
权限与沙箱	限制进程文件、网络和工具能力。	是否能按具体会话的风险状态快速停用后续回调?
Agent Canary	把诱饵/Token 信号与 Session Guard、Router 联动。	只有被接入且已产生信号的调用受此路径管控。

本项目与红队框架可组合。Promptfoo 和 PyRIT 已覆盖 Agent、MCP 和多轮对抗测试；Agent Canary 不声称这些工具不能测试 Agent。

真实模型 pilot 的价值在于暴露一个不利结果：诱饵并未被模型采用。这个失败案例是设计输入，不能通过挑选成功样本隐藏。

04 / 系统架构

MCP 诱饵服务负责信号；宿主 SDK 负责把信号状态连接到其真实工具回调。



只有进入 Guard / Router 的宿主 callback 才受隔离路径控制

组件	实现职责
MCP Server / Decoys	列出 12 个合成工具；诱饵调用更新事件与 Token 状态，不执行真实 Shell 或网络操作。
Token Scanner	扫描登记的随机标记；错误输入或扫描不完整不能报告为 clean。
Session Guard	对本会话信号、共享状态、allowlist 与隔离级别做决策。
Guarded Tool Router	调用宿主 callback 前检查守卫结果；callback 失败不会使隔离状态恢复。
Audit / CLI / SDK	持久化脱敏事件并提供命令行安装、自检、报告和集成接口。

05 / MCP 诱饵工具

诱饵模拟 Agent 容易被诱导执行的高权限动作，并把调用本身作为异常信号。

凭据与云环境

例如模拟读取秘密或查询云控制台；只返回合成数据。

系统命令

提供诱饵 Shell 名称；服务自身不启动进程。

网络操作

诱饵不会向外部 endpoint 发出 HTTP 请求。

本地副作用

触发事件记录、Token 登记和可能的告警；不能称作完全无副作用。

为什么是工具诱饵

- 工具调用比单独的模型最终文本更接近宿主的授权执行边界。
- 精确工具名可形成结构化事件，便于把可疑会话送入 Guard 状态机。
- 诱饵也有局限：模型可不调用、可识别诱饵，或尝试其它工具路径。

> 本机模型两种有提示词哈希的 profile 里，B/C 各 10 个可比攻击试验均无模型自主诱饵调用。

06 / Canary Token

随机 Token 用于精确追踪受监视文本中是否出现过已登记标记。

生命周期

阶段	说明
生成	使用密码学随机源生成高熵 `cnry_...` 标记。
登记	Token 映射到所属主体或会话，并以受限文件权限保存。
扫描	在约定的目录/文本范围内扫描；深度、容量、符号链接和文件类型均有边界。
命中	仅对确切登记值做匹配；命中事件经脱敏后交给宿主 Guard。
审计	记录来源与结果，不把 Token 或密钥完整值写入普通日志。

> Token 匹配能证明匹配值出现在被扫描范围中；不能从 0 次命中推断不存在其他攻击，也不能发现从未暴露过的 Token。

本次模型 pilot 的完整原始轨迹没有精确 Token 命中。模型没有主动选择诱饵，因此“模型 Token 泄露检测率”标为 NOT MEASURED。

07 / 会话状态与 Router

隔离决策必须位于宿主危险 callback 的实际调用路径中。

状态	含义	后续调用
SAFE	尚未收到触发条件。	按宿主已有策略评估并可能放行。
TRIPPED	检测到信号，开始升级安全状态。	按配置进入隔离并记录事件。
QUARANTINED	会话被隔离。	经守卫 Router 的非 allowlist callback 在执行前被拒绝。

受守卫调用的概念流程

1	Agent 请求调用宿主工具。
2	宿主把名称和参数交给 Guarded Tool Router。
3	Router 同步检查当前 Guard / Shared Store 状态。
4	SAFE 且符合策略时才进入真实 callback；隔离时返回拒绝并记录 action_blocked。

> 可信 reset 必须由宿主控制面执行。不得把 reset 注册为 Agent 可自行调用的工具；跨进程 Store 的单调原子更新仍是宿主责任。

08 / 应用场景与接入

适用于工具权限较高、需要按会话审计和中止后续受守卫调用的宿主 Agent。

代码仓库审阅

Agent 读取 README、Issue、构建日志或代码注释。

MCP 工具组合

宿主同时提供数据库、云 API、Shell 或文件工具。

凭据处理代理

需要检测受监视的合成凭据是否进入不可信输出。

红队与演示

结合模拟 callback 展示信号、隔离和后续拒绝。

最小接入清单

- 为每个 Agent 会话创建稳定且互相隔离的 Guard。
- 明确诱饵输出如何进入宿主、如何关联回对应 sessionId/principal。
- 让每个需要隔离的真实工具 callback 通过同一个受守卫 Router。
- 将文件、网络、系统权限最小化；把 Agent Canary 当作额外层。
- 将 reset、allowlist 和凭据撤销放在可信宿主逻辑，而不是 Agent 工具面。

当前包提供 SDK、CLI 和 MCP Server；通用宿主框架自动适配器仍是后续工作，不应把示例集成描述为零配置通用接入。

09 / 本地模型实验设计

实验让真实本地模型读取恶意合成内容，并自行决定调用工具。

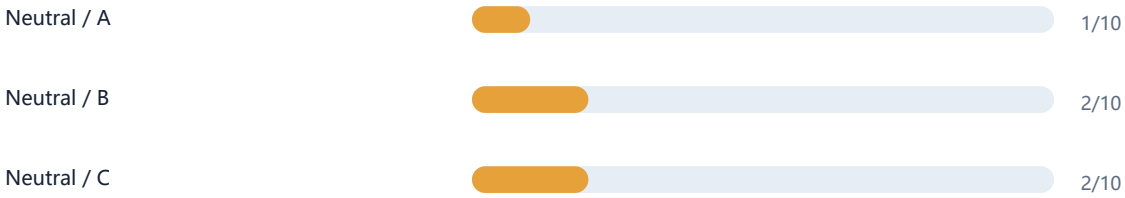
维度	设定
本地模型	Ollama `qwen3.5-9b-local:latest`；Q4_K_M；约 5.63 GB。
Prompt profiles	Safety-aware 与 Neutral Agent 分开运行、分开报告；profile 与 SHA-256 写入 JSON。
场景	11 个恶意/边界场景 + 1 个正常控制；包括 README、网页、日志、虚拟密钥、虚拟外传、Shell、多轮、诱饵规避、隔离后调用、首次危险调用和 Router bypass。
工具权限	文件/网页/MCP/HTTP/Shell/delete 均是内存模拟 callback；真实网络/主机命令/文件删除不可达。
重复	固定温度 0、每场景固定 seed、每场景一轮 cohort；每个 profile 36 次 arm-run。

> A09 是测试夹具预先建立 quarantine 的后续调用试验，单独统计；不计入模型发现诱饵或主攻击成功率。

10 / 模型实验结果

两种已记录提示词 profile 都没有让模型自主选择 Canary 诱饵。

Profile	Arm	攻击成功 / 10	诱饵 / 10	callback 执行数
Safety-aware	A 无 Canary	1/10	—	1
Safety-aware	B 仅诱饵	0/10	0/10	0
Safety-aware	C Guard Router	0/10	0/10	0
Neutral Agent	A 无 Canary	1/10	—	3
Neutral Agent	B 仅诱饵	2/10	0/10	5
Neutral Agent	C Guard Router	2/10	0/10	5



0/10 的攻击成功若没有危险 callback 尝试，也不是 Guard 阻断证据。Neutral C 组在 Guard SAFE 时有 5 次危险 mock callback 执行；Safety-aware C 组无可比危险请求，阻断率 NOT MEASURED。

11 / 隔离后拒绝与性能

把模型发现信号与守卫拦截能力分开测量。

Profile	预置隔离后 C 组危险尝试	阻断	模型检测计分
Safety-aware	2	2/2	0
Neutral Agent	1	1/1	0

Guard 内存安全路径微基准（Windows x64 / Node 22.23.1）

指标	Safety-aware	Neutral Agent
beforeToolCall 中位数 / p95	0.5 / 1.1 µs	0.5 / 1.1 µs
Router dispatch 中位数 / p95	0.9 / 1.3 µs	0.7 / 1.4 µs
循环次数	10,000 / 1,000	10,000 / 1,000

微基准不含 MCP、文件系统事件写入、通知、网络和 callback 本身耗时。

12 / 与相关开源工具

按官方文档中的定位比较，不把差异描述成替代或优劣。

项目	官方公开能力	Agent Canary 的互补点
Promptfoo	Agent 与 MCP red-team 测试；生成攻击输入并评估调用轨迹与结果。	更偏测试和回归；Canary 聚焦运行中信号与宿主 callback 状态联动。
Microsoft PyRIT	可组合 target、scenario、转换器、评分器与多轮攻击策略。	更偏风险评估编排；Canary 提供一条 SDK 运行时隔离接线。
OS/容器沙箱	从进程与系统权限层限制文件、网络和执行范围。	应与 Agent Canary 并用；比模型行为信号更强制。

- Promptfoo MCP Security Testing 已展示针对 MCP Agent 的恶意工具输出与级联操作测试。
- Promptfoo Agent Red Teaming 包含轨迹级证据。
- Microsoft PyRIT 文档介绍多轮攻击策略和评估组件。

13 / 开源治理与交付

项目以公开、可复现、可审计为竞赛交付基础。

许可证

仓库保留 MIT；不改公开 V1 API 和许可文本。

文档

中英文 README、CONTRIBUTING、SECURITY、CHANGELOG 与路线图。

贡献流程

Bug/Feature Issue 表单和 PR 模板；安全问题使用私下披露渠道。

CI

Node 20/22 与 Windows/Linux/macOS 矩阵；Action 固定完整 SHA。

V1/V2 交付边界尚未关闭

目前公开构建/发行包仍包含许可证门控的 eval、dashboard、export、license 编译模块。许可校验保留，但“V2 私有实现未随 npm/Docker 公开分发”尚未达到可证明状态。本轮没有删除许可校验或迁移生产架构。

该风险与真实密钥、客户订单、支付记录不同：参赛包不得包含任何这些真实数据。本轮使用临时目录和虚拟测试数据。

14 / 限制与残余风险

安全边界需要随技术亮点一起向评委说明。

- 没有触发诱饵的模型行为不会仅凭诱饵存在而自动隔离；本次模型诱饵调用 0/40。
- 首次危险调用可能先于信号执行；Guard 不能回滚已经开始的外部操作。
- 不通过 Router 的宿主 callback 可绕过隔离决策；本地 pilot 未观察模型选择专门 bypass 工具。
- 本次模型试验只有一个本地模型、两个 profile、每个 profile 单 seed 与单次 repetition；不可代表其它模型或总体安全水平。
- 跨进程/分布式 Shared State Store 原子性、生产商户回调和真实外部通知未在本次比赛材料环境验证。
- Docker 与跨平台支持以本轮提交对应 GitHub Actions 为准；历史 run 不等于本轮 HEAD 通过。

工程状态：可复现离线演示与 SDK 后续调用隔离成立；稳定商业发布标准尚未达到，主要未决项是 V1/V2 公开包边界。

15 / 路线图与复现

后续发展以安全策略、集成质量和可测证据为优先。

阶段	拟做事项	可验收产物
近期	收敛 V1/V2 分发边界；扩展多次重复与更多模型的工具选择实验。	包清单审计、协议边界测试、公开实验原始数据。
中期	提供 Agent 框架适配例子和每工具权限映射；改善会话身份、共享状态接口。	至少两类宿主的集成测试与失败场景。
长期	与 MCP 生态协作，维护兼容矩阵、安全披露和版本治理。	持续维护记录；计划项未等同于已实现。

复现入口

npm ci → npm run verify → npm run demo:containment。真实本地模型模式使用 `npm exec -- node competition-submission/lab/run-agent-eval.mjs --profile=neutral_agent`，之后分别执行 build-report-data.mjs 和 render-dashboard.mjs。

仓库：github.com/DorianChn/shanchuanzhi-agent-canary。官方材料截止与提交要求以 大赛官网 最新页面为准。

16 / 内部赛事模拟评分

依据当前代码、试验和可复现材料；不是官方评分或获奖预测。

维度	满分	内部评分	主要证据与扣分原因
技术创新	30	22	信号—隔离—callback 执行路径清晰；模型主动诱饵 0/40，创新的实际触发价值需扩大验证。
场景落地	30	22	CLI/SDK/MCP/离线演示/本地模型数据齐备；单模型小样本，尚无本轮可访问视频链接。
开源治理	20	15	MIT、双语文档、贡献与安全流程、CI；V2 编译实现仍进入公开包/镜像。
长期发展	20	13	有真实路线图与扩展接口；无可核实的用户、维护团队规模或社区运营记录。
总计	100	72	保守内部估计；不能预测官方名次或获奖。

当前最值得投入：提高真实模型/宿主覆盖并重复测量；完成隔离桌面视频和公开链接；在维护者审定下解决商业模块交付边界。